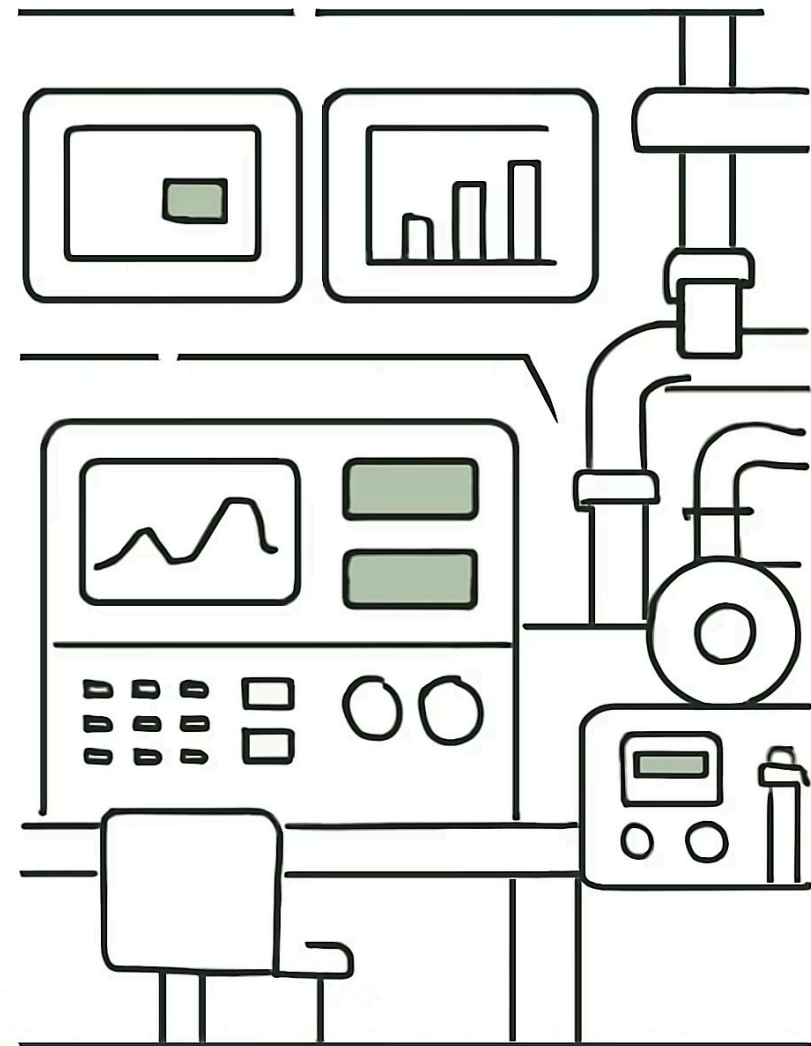


Detectar lo que aún no conocemos: IA para la seguridad de nuestros sistemas industriales

Propuesta de proyecto piloto — Ciberseguridad OT

CYBERSECURITY ANALYST · JUNTA DIRECTIVA · 2025



Nuestras defensas solo detectan amenazas conocidas

El problema

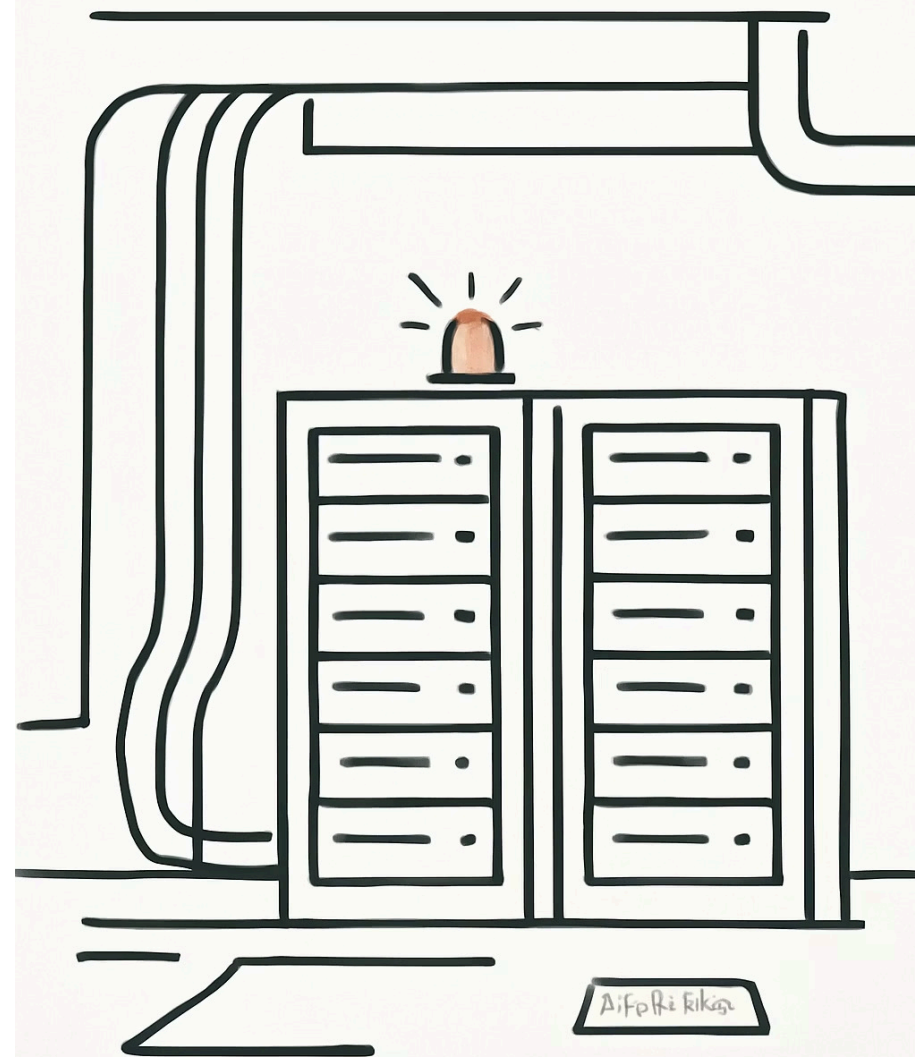
Los sistemas IDS/ICS tradicionales operan con firmas y reglas predefinidas. Si el ataque es nuevo o desconocido, **pasa completamente desapercibido**.

200+

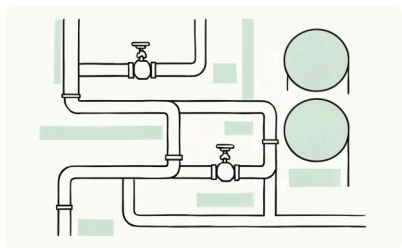
Días de permanencia

Tiempo medio que un atacante permanece en redes OT sin ser detectado en 2024.

¿Cuánto tiempo llevaría un atacante en nuestra red antes de que lo detectáramos?



El sector ya está respondiendo



Colonial Pipeline — 2021

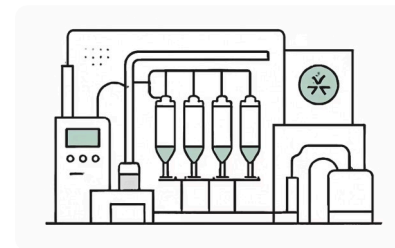
Ataque ransomware que paralizó el suministro de combustible en la costa este de EE.UU. durante seis días.

Rescate pagado: 4,4 M\$.



Red eléctrica de Ucrania — 2015-16

Primer ciberataque documentado que causó apagones masivos. Más de 230.000 hogares sin luz. Vector de entrada: spear-phishing sobre SCADA.



Stuxnet — 2010

El primer arma cibernética dirigida a PLCs Siemens. Demostró que los sistemas OT son objetivos militares y estratégicos de primer nivel.

Ante este panorama, la comunidad investigadora lleva 4 años desarrollando métodos de detección basados en **comportamiento** en lugar de firmas. El artículo IEEE 2024 recoge los avances más recientes en esta línea.



¿Y si el sistema aprendiera qué es «normal» para detectar lo anormal?

El artículo IEEE 2024 propone un modelo de IA que **aprende el comportamiento habitual de los sensores industriales** sin necesitar ejemplos de ataques previos.

i Como un guardia de seguridad que conoce tan bien la rutina del edificio que detecta cualquier desviación — aunque nunca haya visto ese tipo de intrusión antes.

Este enfoque es radicalmente diferente: no busca el ataque conocido. Detecta **lo que no debería estar ocurriendo**.

El sistema en tres pasos



El enfoque es **no supervisado**: no requiere etiquetar ataques previos ni actualizar bases de datos de firmas. El modelo aprende autónomamente y genera alertas ante cualquier anomalía, conocida o desconocida.

Aplicado a nuestra infraestructura



Datos ya disponibles

Nuestros PLCs y sistemas SCADA generan flujos de datos de proceso continuos — exactamente el tipo de señal que este modelo necesita.



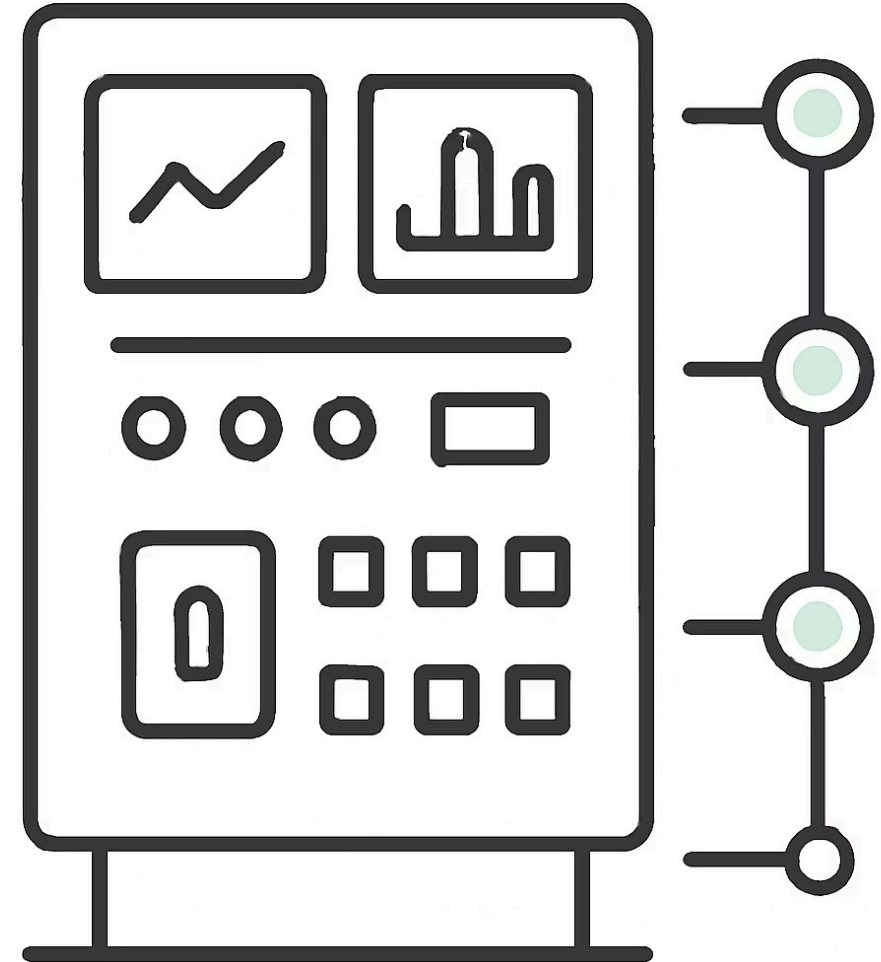
Sin modificar infraestructura

El sistema opera en modo pasivo. No requiere cambios en la red OT existente ni interrupciones operativas.

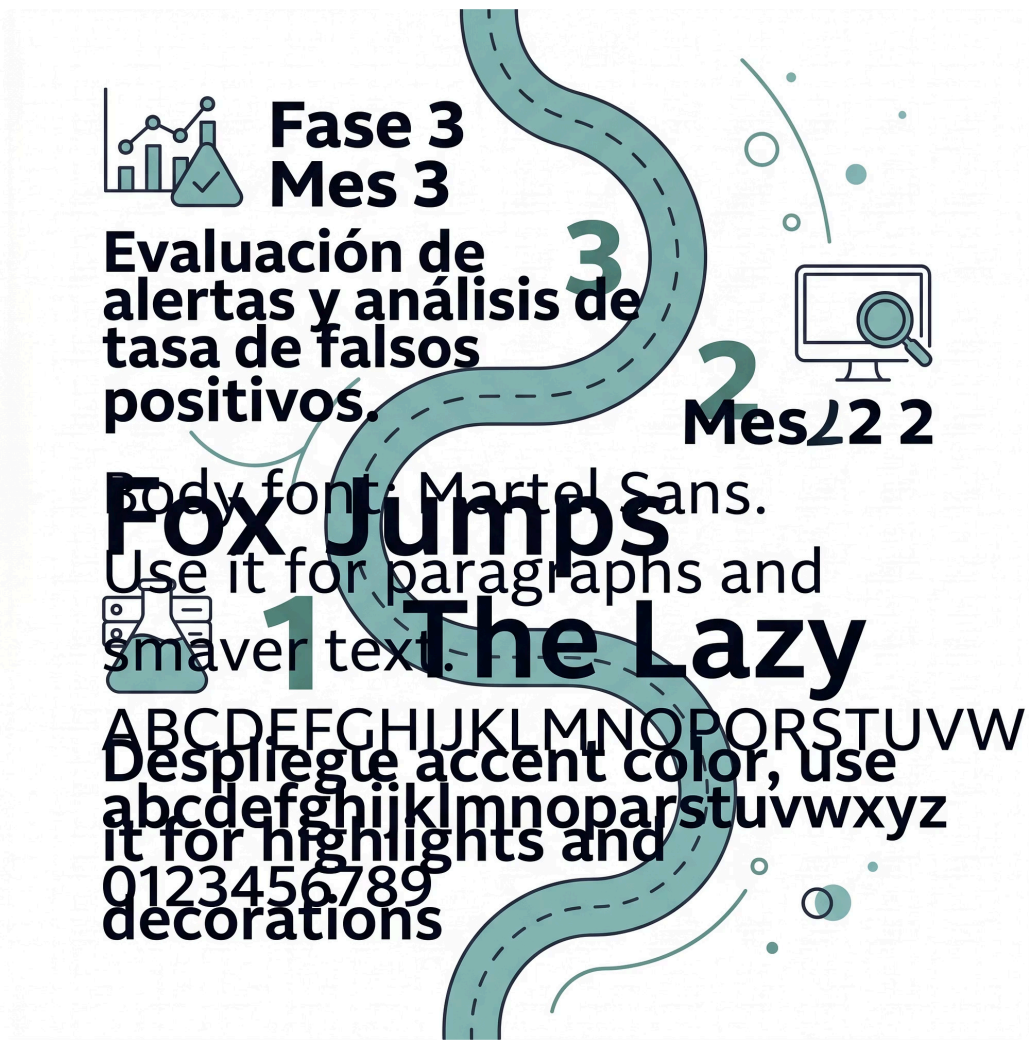


Complementario, no sustitutivo

Se integra junto a Suricata y Wazuh como una capa adicional de visibilidad, potenciando las defensas actuales.



Propuesta: piloto de 3 meses



Recursos necesarios



1 técnico

Dedicación del 50%
durante el trimestre.



Servidor de
inferencia

Coste estimado
acotado y único.
Hardware estándar.



Modelo open-source

Sin licencias. Mantenimiento interno.

Lo que podría fallar y cómo lo controlamos

Riesgo: Exceso de falsos positivos

Un volumen alto de alertas puede saturar al equipo de seguridad.

Mitigación: Umbral de alerta ajustable. Revisión humana en el loop antes de escalar cualquier incidencia.

Riesgo: Baseline insuficiente

Si la red está en un estado atípico durante la fase de aprendizaje, el modelo aprende patrones incorrectos.

Mitigación: El piloto arranca únicamente sobre líneas de producción en estado estable y controlado.

Riesgo: Coste de mantenimiento a largo plazo

La dependencia de proveedores externos puede generar costes recurrentes no previstos.

Mitigación: Modelo open-source con capacidad de soporte y actualización interna.

Qué conseguimos si funciona



Detección en horas

Reducir el tiempo de detección de amenazas desconocidas de **meses a horas**.



Visibilidad real OT

Por primera vez, comprensión profunda del comportamiento real de nuestra red industrial.



Cumplimiento normativo

Refuerza el posicionamiento ante auditorías de **NIS2** e **IEC 62443**.



Base escalable

Si el piloto tiene éxito, la solución puede extenderse a **toda la infraestructura industrial**.

La pregunta no es *si* nos van a atacar.

Tenemos un problema real, una solución validada académicamente y un plan concreto de bajo riesgo para probarla.

- ❑ Solicito aprobación para iniciar el piloto en el próximo trimestre. La única forma de saber si estamos protegidos es comprobarlo **antes de que lo haga alguien por nosotros.**

- ✅ Problema identificado

Amenazas desconocidas sin cobertura actual

- ✅ Solución validada

Artículo IEEE 2024, casos de uso reales

- ✅ Plan de bajo riesgo

Piloto de 3 meses, coste acotado, reversible

